

Information Security Policy

Veltrixa ApS

Document ID	POL-001	Version	1.1
Owner	CEO	Approver	CEO
Effective date	26 July 2026	Next review	26 July 2027
Classification	Internal / Portfolio	Status	Approved for portfolio use

PORTFOLIO DISCLAIMER

This document is an illustrative ISMS artefact for the fictional company Veltrixa ApS. In a production environment, selected requirements in this policy may be supported by separate standards, procedures and work instructions. For this portfolio case, the principal information security requirements are consolidated in this policy. Supporting documents are included only where necessary to demonstrate the design and operation of the ISMS. This document is not evidence of certification or live operational performance.

1. Policy statement

Veltrixa protects information in proportion to business, legal, contractual and customer needs. Information security supports reliable service delivery, responsible innovation and stakeholder trust.

2. Management commitments

- Meet applicable information security, privacy, legal, regulatory and contractual requirements.
- Protect the confidentiality, integrity and availability of information.
- Apply a risk-based approach and implement proportionate controls.
- Set measurable objectives and provide resources needed to achieve them.
- Build security into services, projects, changes and supplier relationships.
- Promote prompt reporting, learning and a constructive security culture.
- Continually improve the suitability, adequacy and effectiveness of the ISMS.

3. Information security policy requirements

All personnel and relevant third parties shall comply with the requirements below. These requirements apply in proportion to information classification, risk, legal and contractual obligations, and the nature of the system or service.

3.1 Access control and account management

- Access shall be granted only for authorized business purposes, based on need -to-know and least privilege, and approved by the relevant system or information owner.
- Each user shall use an individually assigned account. Shared accounts are prohibited unless technically necessary, formally approved, documented and monitored.
- Access rights shall be reviewed periodically and promptly changed or removed following role changes, termination or expiry of a third-party engagement.
- Privileged access shall be restricted, separately assigned where feasible, logged and subject to enhanced review.

3.2 Passwords and authentication

- Passwords shall be unique to Veltrixa services, sufficiently strong for the associated risk and managed using an approved password manager where available.
- Passwords and authentication secrets shall not be shared, transmitted in clear text or stored in unapproved locations.
- Multi-factor authentication shall be enabled for privileged accounts, administrative interfaces, production environments, remote access and other high-risk services where supported.
- Default credentials shall be changed before systems or services are placed into use. Suspected compromise shall be reported immediately and affected credentials reset.

3.3 Acceptable use of information and assets

- Veltrixa information, systems, devices and services shall be used primarily for authorized business purposes and in accordance with applicable law, contracts and internal requirements.

- Users shall not bypass security controls, install unauthorized software, connect unapproved devices or use company resources for unlawful, abusive or materially risky activity.
- Confidential or restricted information shall not be copied to personal accounts, unmanaged devices or unapproved cloud services.
- Company assets shall be protected from loss, theft, damage and unauthorized observation and returned when no longer required.

3.4 Email, messaging and internet use

- Business communications involving sensitive information shall use approved communication channels and appropriate recipient, attachment and classification checks.
- Users shall exercise caution with unexpected links, attachments, payment requests, credential prompts and changes to supplier or customer instructions, and report suspected phishing promptly.
- Automatic forwarding of business email to personal or unapproved accounts is prohibited.
- Sensitive information shall not be sent by ordinary email without appropriate protection where the risk, classification or applicable requirement demands encryption or another secure transfer method.

3.5 Information classification, handling and disposal

- Information shall be classified as Public, Internal, Confidential or Restricted according to its sensitivity, legal obligations and potential impact if disclosed, altered or unavailable.
- Information owners shall define appropriate access, storage, transmission, retention and disposal requirements for the information they are responsible for.
- Confidential and Restricted information shall be accessible only to authorized persons and shall not be discussed or displayed where unauthorized persons may obtain it.
- Information and media shall be securely deleted or destroyed when retention is no longer required, subject to legal holds and documented retention obligations.

3.6 Encryption and key management

- Approved encryption shall be used to protect sensitive information in transit over untrusted networks and at rest where required by risk, classification, law or contract.
- Cryptographic keys, secrets, certificates and tokens shall be created, stored, distributed, rotated, revoked and disposed of using approved methods with access limited to authorized persons and services.
- Encryption shall not be treated as a substitute for appropriate access control, secure configuration, monitoring or data minimization.

3.7 Remote working and mobile devices

- Remote access to Veltrixa systems shall use approved devices, services and secure authentication appropriate to the risk.
- Devices used for business purposes shall be protected by screen locking, supported software, security updates, malware protection where appropriate and encryption where required.
- Personnel shall prevent unauthorized viewing or discussion of sensitive information in public or shared locations and shall secure devices when unattended.
- Loss, theft or suspected compromise of a device used to access Veltrixa information shall be reported immediately.

3.8 Backup, availability and recovery

- Information and system configurations necessary for critical services shall be backed up according to documented recovery and retention needs.
- Backups shall be protected from unauthorized access, alteration and deletion, and restoration shall be tested at planned intervals.
- Critical services shall have documented continuity and recovery arrangements proportionate to business impact, and material failures shall be recorded and addressed.

3.9 Secure development and change management

- Security and privacy requirements shall be considered throughout design, development, testing, deployment, maintenance and retirement.
- Changes to production systems shall be authorized, tested, documented and capable of rollback in proportion to their risk and urgency.
- Development, test and production environments shall be appropriately separated. Production data shall not be used in non-production environments unless specifically authorized and protected.
- Source code, dependencies and technical configurations shall be protected against unauthorized change and reviewed for relevant vulnerabilities before release and throughout their lifecycle.

3.10 Vulnerability, logging and monitoring

- Systems and services shall be securely configured, supported and updated according to their risk and exposure.
- Identified vulnerabilities shall be assessed, prioritized and remediated within timeframes proportionate to their severity and business impact.
- Security-relevant events shall be logged and monitored where necessary to detect misuse, incidents and control failures. Logs shall be protected against unauthorized access and alteration.
- Security testing and monitoring activities shall be authorized, scoped and conducted so they do not create unacceptable operational or privacy risk.

3.11 Supplier and cloud security

- Information security, privacy, resilience and compliance risks shall be assessed before engaging suppliers that access Veltrixa information or support important services.
- Relevant security requirements, responsibilities, incident notification duties, data handling restrictions and exit provisions shall be included in agreements where appropriate.

- Supplier performance and risk shall be reviewed throughout the relationship, with enhanced oversight for critical or high-risk suppliers.
- Access and data held by a supplier shall be returned, transferred or securely deleted at the end of the relationship as contractually and legally required.

3.12 Incident and weakness reporting

- Suspected information security events, weaknesses, policy breaches, loss of information or unusual system behaviour shall be reported immediately through the approved channel.
- Personnel shall preserve relevant evidence and shall not investigate, communicate externally or take disruptive action unless authorized.
- Incidents shall be assessed, contained, resolved, documented and reviewed according to their impact, including legal, regulatory, contractual and customer notification obligations.
- Lessons learned and corrective actions shall be tracked to completion and used to improve the ISMS.

3.13 Physical and environmental security

- Access to offices, work areas, equipment and records shall be limited to authorized persons according to the sensitivity of the assets present.
- Visitors shall be appropriately controlled, and sensitive information shall be protected from unauthorized viewing, removal, damage and environmental threats.
- Paper records and removable media containing sensitive information shall be securely stored and disposed of using approved methods.

3.14 Personnel responsibilities and awareness

- Personnel shall complete required security and privacy awareness activities and understand the responsibilities relevant to their role.
- Confidentiality and information security obligations shall be communicated before access is granted and shall continue after employment or engagement where applicable.
- Managers and control owners shall promote compliance, retain appropriate evidence, address identified gaps and escalate risks that exceed their authority.

4. Applicability and compliance

This policy applies to all employees, contractors and third parties with access to Veltrixa information or systems. Breaches may result in access restriction, contractual or disciplinary action, and legal or regulatory reporting where required. Exceptions require documented risk assessment, defined compensating measures, an expiry date and approval by the ISMS Owner and relevant risk owner.

5. Communication and review

The policy is communicated at onboarding, remains accessible to personnel and is made available to relevant external parties when appropriate. It is reviewed at least annually and after significant change, major incident or material change in requirements.